

ENTERPRISE TECHNICAL STANDARD

CVE-2026-115560 TECHNICAL

THREAT POSTMORTEM

Remote Code Execution Threat Analysis & Multi-Tier Mitigation Architecture

AUTHOR
Andy Setiyawan | Security Engineering

DATE
2026-10-24

CLASSIFICATION
Enterprise Security Standard

STATUS
Production Verified — Akatsuki Lab Fail-Closed

1. Executive Summary & Vulnerability Context

On 2026-10-23, public security advisories disclosed CVE-2026-115560, a remote code execution vulnerability impacting PHP's RFC1867 session upload progress tracking mechanism across PHP 5.5 through PHP 8.4.xx.

Under configurations combining session upload progress with dynamic or dual serialization handlers (such as switching between standard php and php_binary or wddx/memcached), unauthenticated remote attackers can inject arbitrary serialized state via multipart form uploads before authentication logic executes.

Because official upstream bugfix point releases are scheduled for the next regular maintenance cycle, this document establishes a production-grade mitigation architecture providing edge perimeter interception, runtime SAPI deactivation, and in-tree Zend Engine key sanitization.

> **CRITICAL REMEDIATION DIRECTIVE**
> Immediate mitigation: set session.upload_progress.enabled = Off across all active SAPI configurations. For environments requiring upload progress tracking, apply in-tree C-source key sanitization to ext/session/session.c.

2. Threat Mechanics & Serialization Delimiter Exploitation

The vulnerability stems from the engine allocating global tracking arrays within the active session store prior to request authentication. When an attacker submits a multipart form request containing the progress name parameter alongside a custom progress key with serializer control bytes (such as |, !, or curly braces), PHP registers the key verbatim into the session array.

If an application subsequently switches serialization handlers or deserializes session data in a different context, the injected delimiter causes the session decoder to interpret user-controlled strings as instantiated object trees.

Our multi-tier defense architecture decouples protection across three independent layers, ensuring that perimeter edge proxies reject marker injections, FPM workers disable automated tracking, and patched C binaries surgically sanitize keys while preserving legitimate application functionality.

INI CONFIGURATION

```
; Recommended SAPI Runtime Hardening Configuration
; Path: /etc/php/*/fpm/conf.d/99-cve-2026-115560-hardening.ini
session.upload_progress.enabled = Off
session.upload_progress.cleanup = On
session.upload_progress.prefix = "upload_progress_"
session.upload_progress.name = "PHP_SESSION_UPLOAD_PROGRESS"
```

3. Multi-Tier Defense Topology & Mitigation Architecture

To prevent single-point-of-failure vulnerabilities, defense-in-depth is enforced across the reverse proxy perimeter, FastCGI runtime, and Zend Engine source code.

Tier 1 operates at the Nginx reverse-proxy edge, inspecting query parameters and Content-Type boundary headers. Tier 2 enforces runtime SAPI deactivation via namespaced conf.d drop-ins. Tier 3 applies surgical C-level character whitelisting in ext/session/session.c.

Defense Layer	Component Target	Interception Mechanism	Operational Impact
Tier 1 (Perimeter)	Nginx Ingress Proxy	Drops query string progress markers & CRLF boundaries with HTTP 403/400	Zero backend FastCGI worker overhead
Tier 2 (SAPI Runtime)	PHP-FPM / CLI conf.d	99-cve-2026-115560-hardening.ini sets upload_progress.enabled = Off	Disables automated session array allocation
Tier 3 (Zend Core)	ext/session/session.c	Surgically bounds key (1-128) and enforces [a-zA-Z0-9_.-] whitelist	Neutralizes delimiters while preserving safe keys

4. Empirical Lab Verification & Multi-CVE Coexistence

A critical requirement in production maintenance is verifying coexistence with CVE-2026-109618 and CVE-2026-109619 ('PHP2Shell'). Testing confirmed both suites operate without configuration or patch collisions.

In-tree sequential patching on a shared PHP 8.1.34 source tree verified that Patch 1 (CVE-109618 line 3000) and Patch 2 (CVE-115560 line 3037) apply cleanly with strict --fuzz=0 (exit code 0). Rollback of Patch 2 leaves Patch 1 fully intact.

SAPI configuration files utilize isolated namespaces (99-cve-2026-115560-hardening.ini vs 99-cve-2026-hardening.ini), ensuring input nesting and variable caps from prior CVE packages are completely preserved.

MULTI-CVE COEXISTENCE DIRECTIVE

Coexistence Status: Verified without clobbering (--fuzz=0, exit 0). Runtime execution note: CVE-2026-109618's early guard at line 3000 short-circuits execution before line 3037 key sanitization.